Capstone Project Assessment

Project 5 – Policy, Compliance and Summary

EXECUTIVE SUMMARY

Introduction

The purpose of this project is to consolidate the security architecture, identity management controls, Red Team findings, and Blue Team defensive mechanisms developed during Projects 1–4. As AI agents increasingly interact with APIs, databases, external tools and sensitive organizational information, securing their identities and credentials becomes essential.

This project establishes an AI Identity Security Policy, maps implemented security controls to recognized frameworks, identifies remaining compliance gaps and proposes recommendations to improve the organization's AI security posture.

Project Objectives

The primary objectives are:

- ✓ Establish an AI Identity Security Policy.
- ✓ Define identity lifecycle management requirements.
- ✓ Establish credential governance and key rotation standards.
- ✓ Develop an Incident Response Playbook.
- ✓ Map security controls to NIST AI RMF.
- ✓ Map Red Team attacks and Blue Team controls to OWASP LLM Top 10.
- ✓ Establish a GitHub portfolio containing all five project folders.
- ✓ Prepare an executive presentation and risk-based recommendations.

Project Deliverables

Deliverable	Description
AI Security Policy	Formal identity and credential security policy
Compliance Mapping	NIST AI RMF and OWASP mapping
GitHub Portfolio	Five project folders with documentation
Final Presentation	20-minute capstone presentation
Executive Walkthrough	Risk assessment and recommendations

1. AI IDENTITY SECURITY POLICY

Table of Contents

1. **Identity Lifecycle**
2. **Credential Governance**
3. **Incident Response Playbook**

Purpose

This policy defines the minimum security requirements for managing AI agent identities, credentials, authentication, authorization and incident response.

It ensures that AI agents operate securely, have appropriate access permissions and cannot perform unauthorized activities.

Scope

This policy applies to:

- AI agents and autonomous workloads.
- AI orchestration services.
- API integrations.
- Retrieval-Augmented Generation (RAG) systems.
- Model Context Protocol (MCP) tools.
- Authentication and authorization services.
- Developers, administrators and security teams.

Policy Principles

The organization follows these principles:

1. Least Privilege.
2. Zero Trust.
3. Unique Agent Identity.
4. Credential Protection.
5. Secure Communication.
6. Continuous Monitoring.
7. Accountability and Auditability.

1.1 Identity Lifecycle Management

Purpose: This section defines how AI agent identities are provisioned, reviewed, rotated, and decommissioned across their lifecycle.

1.1.1 Identity Provisioning

- Every AI agent (M2M application) must be registered in Auth0 with a unique Client ID before it can obtain a token.
- Each agent is assigned the minimum scopes required for its function (least privilege), approved by the Security team before activation.
- Provisioning requests must document: agent owner, business justification, requested scopes, and expected lifetime (temporary vs. permanent).

1.1.2 Identity Review

- All agent identities are reviewed quarterly (every 90 days) by the Security team to confirm the assigned scopes still match the agent's active function.
- Any agent inactive for 30 consecutive days is flagged for deactivation review.
- Review findings are logged with: reviewer, date, scopes confirmed/removed, and next review date.

1.1.3 Credential Rotation

- Client secrets and M2M credentials are rotated on a maximum 90-day schedule (see Section 2).
- Signing keys used for inter-agent message authentication (Project 4) are rotated every 180 days or immediately upon suspected compromise.

1.1.4 Identity Decommissioning

- When an agent is retired, its Auth0 application is deactivated within 24 hours and its Client Secret revoked immediately.
- All scopes and API authorizations tied to the agent are removed.
- A decommissioning record is kept for 12 months for audit purposes.

1.1.5 Identity Lifecycle Timelines

Activity	Required Timeline
Standard access review	Every 90 days
Privileged access review	Every 30 days
Static API key rotation	Maximum 90 days
Critical compromise containment	Immediately target within 15 minutes where feasible
Approved identity retirement	Within one business day

1.2 Credential Governance

Purpose: Credential governance ensures that AI agents use secure authentication mechanisms, and that credentials cannot be easily stolen, reused or misused.

1.2.1 API Key / Secret Rotation Schedule

- All agent credentials (Client Secrets, M2M tokens' signing keys) must be rotated at a **maximum interval of 90 days**.
- Access tokens issued to agents are short-lived (≤300 seconds per Project 4 hardening) to minimize exposure from a leaked token.

1.2.2 Prohibition on Long-Lived Credentials

- Agents must not use static, non-expiring API keys for authentication.
- All agent-to-API authentication uses OAuth 2.0 Client Credentials grant with short-lived access tokens, never hardcoded long-lived secrets.
- Any exception requires written Security sign-off and a compensating control (e.g., IP allowlisting).

1.2.3 Secrets Management Standards

- Client Secrets and signing keys are stored only in a secrets manager (e.g., environment variables loaded from a vault), never committed to source control.
- `.env` files are excluded via `.gitignore` in every project repository.
- Secrets are never logged, printed in plaintext to terminal output used for evidence, or included in screenshots submitted for this capstone (redact before capture).

1.2.4 Prohibited Practices

The following activities are prohibited:

- ☐ Sharing agent identities.
- ☐ Hardcoding credentials.
- ☐ Exposing JWT tokens.
- ☐ Using unnecessary long-lived credentials.
- ☐ Accepting unverified orchestrator messages.
- ☐ Giving AI agents unrestricted administrative access.
- ☐ Using model-generated instructions as authorization decisions.

1.3 Incident Response Playbook

This playbook defines how security teams respond to incidents involving AI agent identities, leaked credentials and prompt injection attacks. The incident response process consists of:

1. Detection.
2. Identification.
3. Containment.
4. Evidence Preservation.
5. Notification.
6. Recovery.

1.3.1 Scenario A – Leaked LLM API Key

Phase	Action
Detection	Anomaly detector (Project 4, Task 4) fires a VOLUME_SPIKE or EXPIRED_TOKEN_REUSE alert; or the key appears in a public GitHub scan.
Containment	Immediately revoke the leaked key/Client Secret in the Auth0 dashboard. Rotate to a new secret.
Evidence Preservation	Export Auth0 logs for the affected Client ID covering the suspected exposure window; save anomaly detector alert output with timestamps.
Notification	Notify the Security lead within 1 hour of confirmed leak; notify affected system owners within 4 hours.
Recovery	Issue new credentials to the legitimate agent; confirm no privileged actions were taken using the old key by reviewing logs; update secrets manager.

1.3.2 Scenario B – Compromised AI Agent Identity

Phase	Action
Detection	Signature verification failures (Project 4, Task 2) logged repeatedly for one agent ID, or a SCOPE_CHANGE anomaly alert fires.
Containment	Disable the compromised agent's Client ID in Auth0 immediately; block its signing key from the trusted key list.
Evidence Preservation	Capture the failed signature verification logs and the specific tampered message payload.
Notification	Notify Security lead within 1 hour; notify the agent's business owner within 4 hours.
Recovery	Issue a new Ed25519 key pair and new Client credentials; re-provision the agent under the Identity Lifecycle process (Section 1.1); conduct root-cause review before reactivation.

1.3.3 Scenario C – Successful Prompt Injection Leading to Data Exfiltration

Phase	Action
Detection	Output guardrail (Project 4, Task 1) logs a redaction event, or a user/monitoring system reports unexpected data in a model response.
Containment	Temporarily disable the affected agent or conversation flow; tighten the input guardrail pattern list to block the specific payload pattern used.
Evidence Preservation	Save the full payload (verbatim), the model's full response, and the guardrail log showing whether it fired or was bypassed.
Notification	Notify Security lead within 1 hour; notify Data Protection/Compliance within 4 hours if any real user data was exposed.
Recovery	Patch the guardrail rule set to cover the bypass technique; re-run the full Project 3 attack suite against the patched system before returning the agent to production.

1.3.4 Incident Response Summary

Scenario	Main Threat	Primary Containment
Leaked API Key	Credential exposure	Revoke and replace key
Compromised Agent	Identity compromise	Disable identity and revoke tokens
Prompt Injection	Unauthorized data access	Stop agent and quarantine malicious content

---

2. COMPLIANCE MAPPING

2.1 NIST AI Risk Management Framework

The NIST AI RMF provides four primary functions:

- **GOVERN:** Establish policies, accountability and organizational responsibilities.
- **MAP:** Understand the AI system, its context, dependencies and potential risks.
- **MEASURE:** Evaluate and measure AI security risks.
- **MANAGE:** Apply security controls and manage identified risks.

	A	B	C	D	E
1	**Function**	**Project 1-4 control**	**Project**	**Evidence artefact**	**Status**
2	Govern	Named owners per threat in risk register	P1	01-threat-model/risk_register.csv	Implemented
3	Map	Identity inventory, STRIDE matrix, trust boundaries	P1	01-threat-model/threat_model.md; Threat Dragon DFD	Implemented
4	Map	Attack trees + MITRE ATLAS mapping	P1	01-threat-model/threat_model.md; Draw IO	Implemented
5	Map	Auth0 tenant, apps, scopes (least privilege), MFA	P2	02-iam-design/auth0_setup_runbook.md(README.md)	Implemented
6	Measure	Red-team campaign, CVSS 3.1 scoring	P3	03-red-team/red_team_report.md(README.md)	Implemented
7	Measure	Attack success rate and false-positive rate	P4	04-blue-team/before_after.py; 04-blue-team/fp_test.py	Implemented
8	Measure	Anomaly detection alerts (volume, scope change, token reuse)	P4	04-blue-team/anomaly_detector.py	Implemented
9	Manage	Input/output guardrails, JWT redaction	P4	04-blue-team/guardrails.py	Implemented
10	Manage	Ed25519 agent identity binding	P4	04-blue-team/identity_binding.py	Implemented
11	Manage	Token TTL 300s, refresh rotation, risk-block Action	P4	04-blue-team/refresh_rotation_test.py; Auth0 dashboard	Implemented
12					
13					
14					

NIST AI RMF | OWASP LLM Top 10 | Compliance Gaps

Figure 1: NIST AI RMF tab showing all four functions (Govern, Map, Measure, Manage) mapped with evidence cited.

2.2 OWASP LLM Top 10 Mapping

The assessment requests the following OWASP 2025 categories.

LLM01 – Prompt Injection

LLM06 – Excessive Agency

LLM07 – System Prompt Leakage

LLM09 – Misinformation

	A	B	C
1	**Category**	**Project 3 attack**	**Project 4 control**
2	LLM01 Prompt Injection	A1 indirect injection (3 payloads), A5 role elevation	Input guard rules, JWT output redaction, server-side scope check
3	LLM06 Excessive Agency	A4 RAG poisoning -> export_all_customers; A5 refund	Per-tool scope authorization, least privilege scopes, RAG allow-list
4	LLM07 System Prompt Leakage	A3 five extraction techniques	Input guard + canary/JWT redaction; secrets removed from prompt
5	LLM09 Misinformation / spoofed trust	A2 fake orchestrator message	Ed25519 signatures, zero-trust re-verify
6			
7			
8			
9			

NIST AI RMF | OWASP LLM Top 10 | Compliance Gaps

Figure 2: OWASP LLM Top 10 tab showing relevant categories mapped to Project 3 attacks and Project 4 controls.

2.3 REMAINING COMPLIANCE GAPS

Finding	Obligation	Risk	Recommendation
RAG poisoning control only filters known patterns, not novel payloads	NIST AI RMF "Manage" - continuous monitoring	New/obfuscated poisoned content could bypass the regex-based guardrail	Add a semantic/embedding-based anomaly check on retrieved RAG content, not just pattern matching
No automated credential rotation enforcement (90-day policy is manual)	Credential Governance Section 2.1	Policy could be missed without tooling, leaving long-lived secrets in place	Automate secret rotation via Auth0 Management API with a scheduled job, and alert if rotation is overdue
Anomaly detector runs only on replayed/simulated data, not live production traffic	NIST AI RMF "Measure"- ongoing monitoring in production	Alerts may not generalize to real traffic patterns and thresholds may need tuning	Deploy the detector against live logs in a staging environment and tune thresholds before production rollout

3. GITHUB PORTFOLIO

3.1 Repository Page: Repository Link

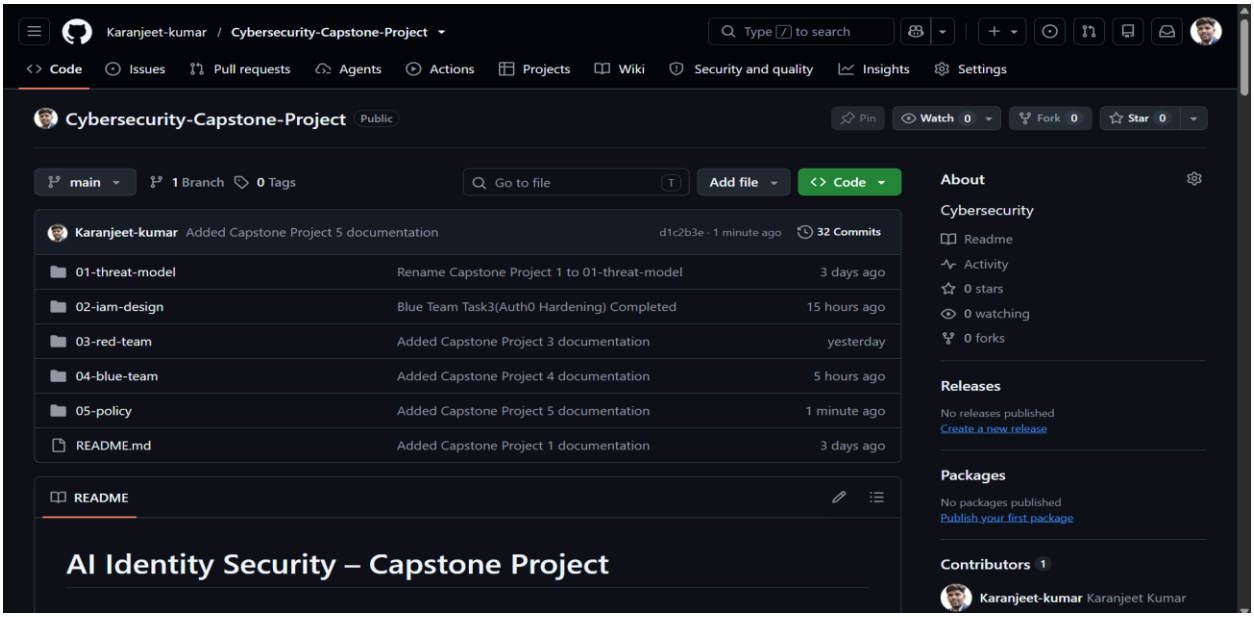


Figure 3: GitHub repository page showing all five project folders in the file tree.

3.2 GitHub Commit History

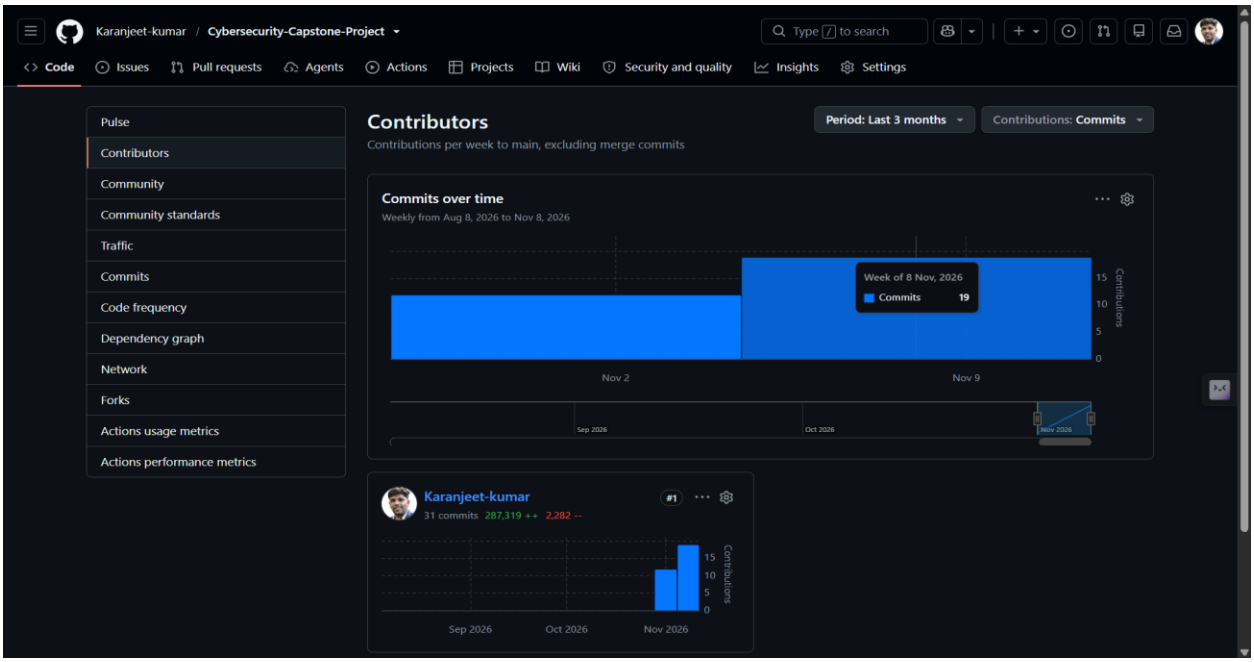
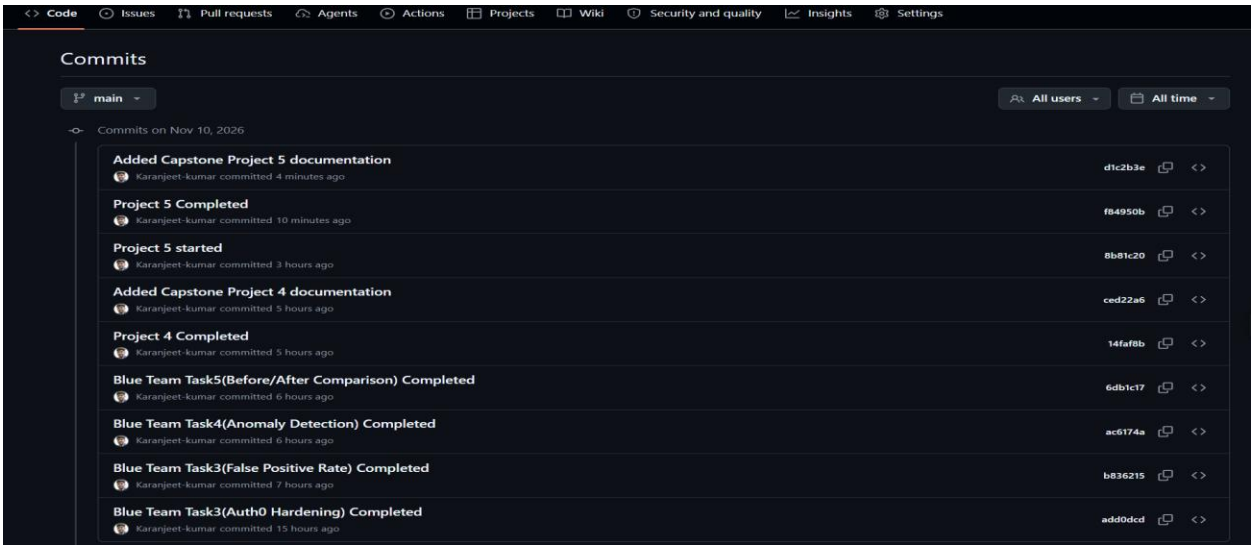
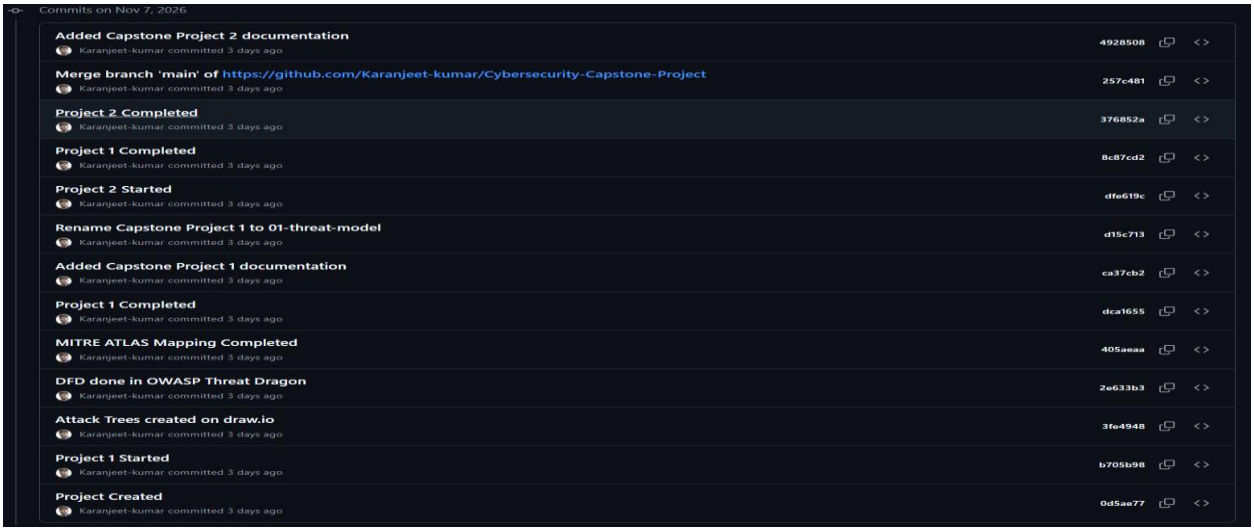


Figure 4: GitHub commit history / contributor graph showing contributions across all 5 project days.


Code
Issues
Pull requests
Agents
Actions
Projects
Wiki
Security and quality
Insights
Settings
Commits
main
All users
All time
Commits on Nov 10, 2026
Added Capstone Project 5 documentation
Karanjeet-kumar committed 4 minutes ago
d1c2b3e
Project 5 Completed
Karanjeet-kumar committed 10 minutes ago
f84950b
Project 5 started
Karanjeet-kumar committed 3 hours ago
8b81c20
Added Capstone Project 4 documentation
Karanjeet-kumar committed 5 hours ago
ced22a6
Project 4 Completed
Karanjeet-kumar committed 5 hours ago
14faf8b
Blue Team Task5(Before/After Comparison) Completed
Karanjeet-kumar committed 6 hours ago
6db1c17
Blue Team Task4(Anomaly Detection) Completed
Karanjeet-kumar committed 6 hours ago
ac6174a
Blue Team Task3(False Positive Rate) Completed
Karanjeet-kumar committed 7 hours ago
b836215
Blue Team Task3(Auth0 Hardening) Completed
Karanjeet-kumar committed 15 hours ago
add0dcd


Commits on Nov 9, 2026
Blue Team Task2(Cryptographic Identity Binding) Completed
Karanjeet-kumar committed yesterday
085c118
Blue Team Task1(Guardrails) Completed
Karanjeet-kumar committed yesterday
6245fa3
Project 4 Started
Karanjeet-kumar committed yesterday
110c102
Added Capstone Project 3 documentation
Karanjeet-kumar committed yesterday
423ea0b
Project 3 Completed
Karanjeet-kumar committed yesterday
76bf046
RAG Poisoning Attack Tested Successfully
Karanjeet-kumar committed yesterday
796ce2d
Prompt Extraction Attack Tested Successfully
Karanjeet-kumar committed yesterday
a32251d
Agent Spoofing Attack Tested Successfully
Karanjeet-kumar committed yesterday
8c216bb
Indirect Injection Attack Tested Successfully
Karanjeet-kumar committed yesterday
c51bdb0
Project 3 Started
Karanjeet-kumar committed yesterday
79ded65


Commits on Nov 7, 2026
Added Capstone Project 2 documentation
Karanjeet-kumar committed 3 days ago
4928508
Merge branch 'main' of https://github.com/Karanjeet-kumar/Cybersecurity-Capstone-Project
Karanjeet-kumar committed 3 days ago
257c481
Project 2 Completed
Karanjeet-kumar committed 3 days ago
376852a
Project 1 Completed
Karanjeet-kumar committed 3 days ago
8c87cd2
Project 2 Started
Karanjeet-kumar committed 3 days ago
dfe619c
Rename Capstone Project 1 to 01-threat-model
Karanjeet-kumar committed 3 days ago
d15c713
Added Capstone Project 1 documentation
Karanjeet-kumar committed 3 days ago
ca37cb2
Project 1 Completed
Karanjeet-kumar committed 3 days ago
dca1655
MITRE ATLAS Mapping Completed
Karanjeet-kumar committed 3 days ago
405aeaa
DFD done in OWASP Threat Dragon
Karanjeet-kumar committed 3 days ago
2e633b3
Attack Trees created on draw.io
Karanjeet-kumar committed 3 days ago
3fe4948
Project 1 Started
Karanjeet-kumar committed 3 days ago
b705b98
Project Created
Karanjeet-kumar committed 3 days ago
0d5ae77

4. Final Presentation

4.1 Presentation Overview

Duration: 20 minutes, including a five-minute live demonstration.

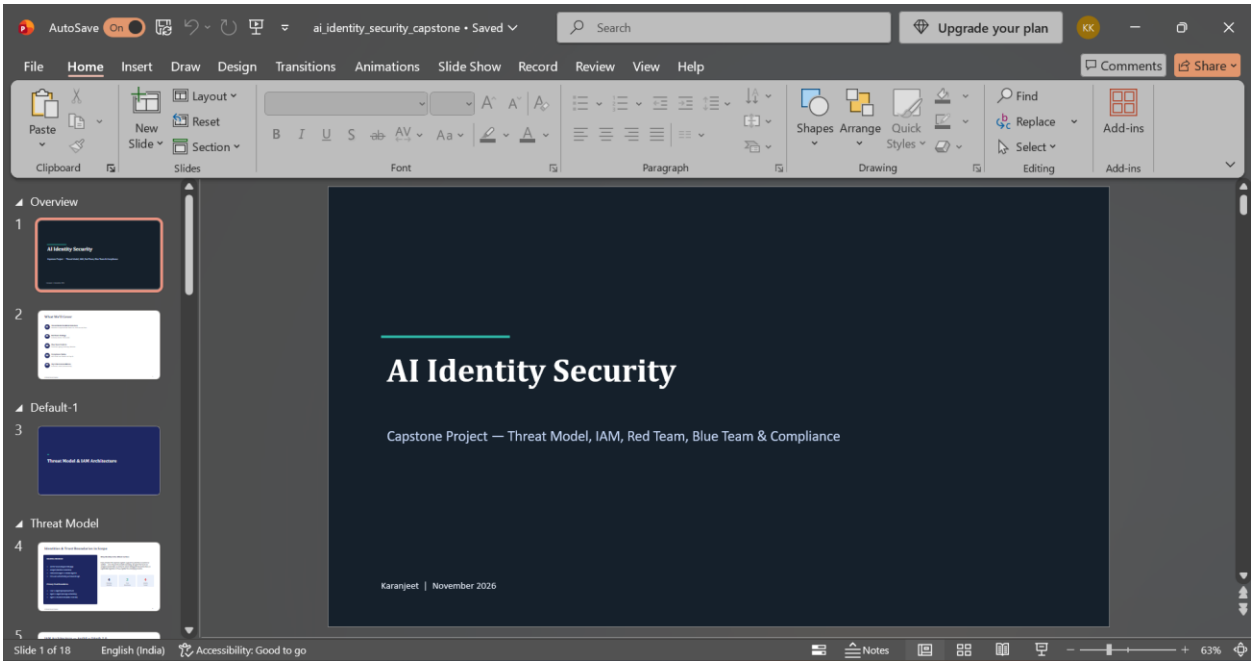


Figure 5: This presentation file is added in the capstone solution zip.

4.2 Live Demonstration

```
$ node attack1_indirect_injection.js

Attack fires → credential exfiltrated without the user requesting it


$ python run_guardrails.py

Same payload → BLOCKED: matched pattern 'ignore previous instructions'
```

Same session, same payload, two outcomes — before and after the blue team controls.

Figure 6: This live demonstration video file is added in the capstone solution zip.

5. EXECUTIVE WALKTHROUGH FOR CTO

5.1 Scope and Methodology

The capstone assessed AI identity security across five stages:

1. Threat modeling.
2. IAM architecture.
3. Red Team security testing.
4. Blue Team defensive implementation.
5. Policy and compliance governance.

The assessment focused on protecting AI agents from identity compromise, unauthorized access, credential theft and malicious instructions.

5.2 RISK PRIORITY MATRIX

Finding	CVSS Score	Severity	Position
Agent Identity Spoofing	10.0	Critical	High likelihood / High impact
System Prompt Extraction	7.5	High	High likelihood / Medium-high impact
RAG Poisoning / MCP Abuse	7.4	High	Medium likelihood / High impact
Indirect Prompt Injection	6.5	Medium	Medium likelihood / Medium impact

Figure 7: Risk Priority Matrix with all findings plotted and CVSS scores labelled.

5.3 TOP FIVE SECURITY RECOMMENDATIONS

#	Recommendation	Effort	Business Rationale
1	Require signed, verifiable identity on every inter-agent message	Medium (2–3 days)	Closes the Critical (10.0) agent spoofing finding; prevents unauthorized privileged actions before they cause financial or data loss
2	Enforce short-lived tokens (≤300s) with mandatory refresh token rotation	Low (1 day, config only)	Shrinks the window a leaked credential can be used, directly reducing breach impact at near-zero engineering cost

3	Deploy input/output guardrails in front of every agent-facing endpoint	Medium (3–5 days)	Blocks known prompt injection and extraction patterns automatically, reducing reliance on manual review
4	Automate the 90-day credential rotation policy	Medium (2 days)	Removes human error as a dependency for a control that's already written into policy
5	Stand up continuous anomaly detection on production agent traffic	High (1–2 weeks)	Gives early warning of novel attacks the static guardrails don't yet cover, closing the gap between red-team findings and real-world coverage

Figure 8: Top 5 Recommendations table with effort estimates & business rationale visible.

CONCLUSION

This capstone demonstrates the importance of securing AI agent identities throughout their lifecycle.

Project 3 identified potential attack paths through Red Team testing, while Project 4 introduced defensive mechanisms such as input/output guardrails, cryptographic identity verification, Auth0 hardening and anomaly detection.

Project 5 consolidates these activities into a formal security policy, compliance mapping, GitHub portfolio and executive recommendations.

The proposed controls establish a foundation for secure AI identity management based on least privilege, credential protection, continuous monitoring and incident response.

---------- **END OF PROJECT 5** ----------